Relatório de Auditoria de Segurança — Painel de Estudos v1.7

Data: 12/11/2026

Escopo

Atualização da cópia pública painel-de-estudos da v1 para a v1.7 (dados fictícios), antes do push: backend FastAPI + SQLAlchemy + SQLite, frontend React + Vite + TypeScript, Dockerfile, docker-compose, bundle compilado, prints e guia em PDF. Foco no que mudou desde a v1: histórico, cronômetro, desempenho, prints e pasta de materiais, cards, transcrições, rodapé e CI.

Stack detectada e como cada categoria foi mapeada

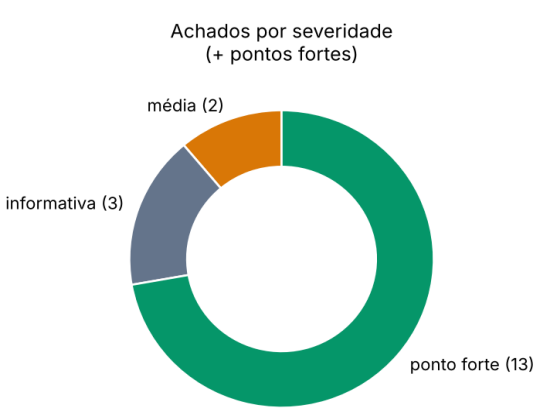
App local de um usuário, sem autenticação (SPEC D1), porta presa a 127.0.0.1. (1) Isolamento: não há tenant; foi auditado o isolamento de rede (loopback, Host, CORS, CSRF). (2) Permissão no navegador e (3) IDOR: não há papéis nem donos; todos os routers foram percorridos para confirmar. (4) Chaves: código, compose, .env.example, histórico git e bundle. (5) XSS: sinks no React e renderização da saída do modelo. Além das cinco, foram auditados cabeçalhos HTTP, dependências (pip-audit, npm audit) e o container.

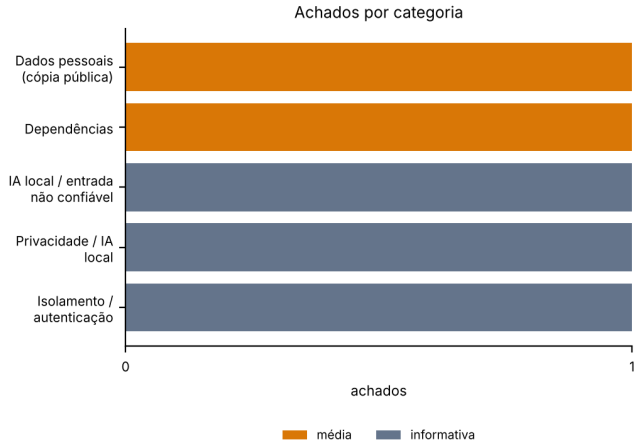
Método

Leitura de código + testes contra o app rodando (curl): Host forjado, POST text/plain, POST com Origin e Sec-Fetch-Site de outro site nas rotas novas, travessia de caminho na pasta de materiais e nos arquivos estáticos; os testes automáticos de travessia e de escrita de outro site; grep de segredos e dados pessoais; OCR dos prints (ampliados, com controle) e texto do PDF; pip-audit e npm audit.

Resumo executivo

Severidade	Total	Corrigidos	Abertos	Aceitos
CRÍTICA	0	0	0	0
ALTA	0	0	0	0
MÉDIA	2	2	0	0
BAIXA	0	0	0	0
INFORMATIVA	3	0	0	3
PONTO FORTE	13	—	—	—





5 achados: nenhum crítico nem alto. Os dados pessoais (média) e o POST de outro site (baixa) foram corrigidos antes da publicação e o container agora roda sem root (baixa). **Nenhum aberto**; 1 risco aceito por decisão do SPEC (sem login).

Pontos fortes

✔ **Porta só no loopback** — docker-compose.yml publica 127.0.0.1:8000; nada exposto na rede.

✔ **Host validado (DNS rebinding)** — Host: evil.com → 400 contra o app rodando.

✔ **Escrita só da própria página, rotas novas incluídas** — POST /api/cards/round com Origin externo → 403; POST /api/cards/{id}/review com Sec-Fetch-Site cross-site → 403; text/plain → 422.

✔ **Pasta de materiais** — Montada só para leitura; /api/prints/folder?path=../../etc → 400 "Caminho fora da pasta de materiais"; testes de travessia para prints e transcrições.

✔ **Limites de entrada** — Transcrição: 30 mil caracteres colados ou arquivo até 2 MB; imagens: 15 MB, 40 por análise, PDF até 30 páginas, reduzidas a 1280 px antes do modelo.

✔ **Links dinâmicos controlados** — Link do Notion no card sempre começa com https://www.notion.so/; links do rodapé só aceitam https:// (no servidor e na tela), com rel="noopener noreferrer".

✔ **Cabeçalhos de segurança** — CSP só 'self', frame-ancestors 'none', X-Frame-Options DENY, nosniff, no-referrer.

✔ **Sem SQL cru com f-string** — Acesso ao banco pelo ORM; migrações usam parâmetros nomeados.

✔ **Sem sinks de XSS** — Nenhum dangerouslySetInnerHTML, innerHTML, eval, new Function ou window.open; saída do modelo renderizada como texto.

✔ **Sem segredos** — Busca por padrões (ntn_, secret_, sk-, ghp_, github_pat_, AIza, GOCSPX-, chave privada, refresh_token): nenhum resultado no código, docs ou compose.

✔ **Arquivos estáticos seguros** — /..%2f..%2fetc%2fpasswd devolve o index.html.

✔ **Dependências limpas** — pip-audit: nenhuma vulnerabilidade (depois do #2); npm audit: 0.

✔ **CI** — GitHub Actions em todo pull request: ruff + pytest (103 testes) e tsc + vitest (14) + build.

Pontos fracos (riscos centrais)

1. O app confia na rede: sem login, a defesa contra páginas maliciosas no navegador é a porta no loopback + Host validado + bloqueio de escrita vinda de outro site (#1).

2. A cópia pública nasce da privada: sem a limpeza (#2), dados pessoais iriam junto.

3. Container rodava como root — corrigido (#3); falta só conferir no Windows.

Categorias do prompt que não se aplicam

1. Banco sem tranca (tenant) — App de um usuário só, sem contas nem tenants (SPEC D1).

2. Permissão no navegador — Não existem papéis no frontend nem no backend.

3. IDOR — As rotas novas por ID (cards, histórico, provas e prazos, cronômetro) foram percorridas: todo objeto pertence ao único usuário.

4. Chaves expostas — Aplicável e verificado: nenhum achado (ver pontos fortes).

5. XSS — Aplicável e verificado: nenhum achado (ver pontos fortes).

Achados detalhados

Dados pessoais (cópia pública)

Sev.	Arquivo:linha	Descrição	Status
MÉDIA	backend/tests, frontend/src, settings_store.py, .env.example, AppFooter.tsx, docs/propostas, SPEC.md, CLAUDE.md	**#1 Dados reais do dono na atualização exportada da versão privada** As versões v1.3 a v1.7 trouxeram de volta dados do dono: nomes reais de disciplinas e do polo nos testes, ids de regra com o nome da faculdade, nome do dono no rodapé e em comentários, links do GitHub e do LinkedIn do dono como padrão nas Configurações, o caminho real da pasta de materiais no .env.example e nas decisões do SPEC, e duas imagens de proposta com a agenda e as disciplinas reais. *Correção:* Mesmo mapeamento da v1 (disciplinas, polo e regras fictícios); links do rodapé vazios por padrão; rodapé "© <ano> Painel de Estudos"; caminho de exemplo no .env.example; SPEC e CLAUDE.md sem nome, caminho ou datas da faculdade; docs/propostas fora da cópia pública; prints e guia refeitos com atividade fictícia. Conferido por grep, texto do PDF e OCR dos 21 prints (ampliados 2×, com controle: o título foi lido em 21 de 21).	corrigido

Dependências

Sev.	Arquivo:linha	Descrição	Status
MÉDIA	backend/requirements.txt	**#2 Pillow 12.1.1 com vulnerabilidades conhecidas** A v1.3 passou a abrir imagens (prints das respostas, de páginas do Notion ou da pasta de materiais) com o Pillow 12.1.1, que o pip-audit apontou com 75 vulnerabilidades conhecidas. Um arquivo de imagem preparado poderia explorar o decodificador dentro do container. *Correção:* Pillow 13.0.0 (v1.7). pip-audit -r backend/requirements.txt: nenhuma vulnerabilidade; npm audit: 0.	corrigido

IA local / entrada não confiável

Sev.	Arquivo:linha	Descrição	Status
INFORMATIVA	backend/app/cards.py, backend/app/integrations/prints.py, backend/prompts/read_print*.md	**#3 Instruções escondidas em prints ou transcrições (prompt injection)** Prints e transcrições vão como material para o modelo local. Um texto ali dentro pode tentar mudar o comportamento do modelo. O modelo não tem ferramentas nem acesso à rede ou a arquivos; a saída é validada por schema Pydantic e mostrada como texto. O pior caso é um card ou uma nota proposta errada; a nota só é salva depois que o dono confirma. *Correção:* Nenhuma ação agora (SPEC D17, D36).	aceito

Privacidade / IA local

Sev.	Arquivo:linha	Descrição	Status
INFORMATIVA	backend/app/agent/router.py, backend/app/study.py, settings_store.py	**#4 Prints e resumo dos números de estudo vão para o modelo local** Exceção decidida no SPEC (D17/D18, D25, D36): prints das respostas e um resumo curto de horas, notas e temas vão só para o modelo local (LM Studio ou Ollama no próprio PC). O resumo dá para desligar em Configurações. Nada vai para IA na nuvem. *Correção:* Nenhuma ação agora.	aceito

Isolamento / autenticação

Sev.	Arquivo:linha	Descrição	Status
INFORMATIVA	docker-compose.yml	**#5 Sem login, por decisão do SPEC (D1)** Igual à v1: a barreira é a porta presa ao loopback + validação de Host + bloqueio de escrita vinda de outro site, conferido também nas rotas novas. *Correção:* Nenhuma ação agora.	aceito

Trechos de código (antes da correção)

#1 · backend/tests, frontend/src, settings_store.py, .env.example, AppFooter.tsx, docs/propostas, SPEC.md, CLAUDE.md

```
"github_url": (str | None, "https://github.com/<dono>", ...)
# PAINEL_MATERIALS_HOST=D:/<caminho real>
```

#2 · backend/requirements.txt

```
pillow==12.1.1
```

#3 · backend/app/cards.py, backend/app/integrations/prints.py, backend/prompts/read_print*.md

```
material.append(f"TRECHOS DE VÍDEO ({transcript_label}):\n{transcript[:MAX_TRANSCRIPT]}")
```

#4 · backend/app/agent/router.py, backend/app/study.py, settings_store.py

```
"agent_reads_metrics": (bool, True, ...)
```

#5 · docker-compose.yml

```
- "127.0.0.1:8000:8000"
```

Recomendações priorizadas

P2 — No Docker Desktop do Windows, depois do docker compose up --build, conferir que o painel sobe e mostra a data de hoje depois das 21:00 (fuso America/Sao_Paulo da v1.7).

P3 — Ativar Dependabot ou rodar npm audit e pip-audit a cada atualização.

P3 — A cada nova versão pública: repetir grep + OCR dos prints e deixar fora as imagens de proposta.

Checklist antes do deploy

Item	Situação
Rodei o prompt e li o PDF inteiro	Para o dono fazer: ler este relatório.
Todo endpoint com ID valida o dono	Não se aplica: um usuário só.
Toda listagem filtra por usuário/tenant	Não se aplica: sem tenants.
Permissão escondida no front é conferida no servidor	Não se aplica: sem papéis.
Nenhum segredo no código, bundle, compose ou CI	OK: verificado.
Busca no histórico git e revogação	OK: o histórico público só tem a v1 e esta atualização; nada a revogar.
Input validado antes de virar HTML	OK: React escapa; sem sinks de HTML; links dinâmicos só https.
Supabase: RLS e service_role	Não se aplica: SQLite local.
Achados viraram issue ou advisory	Achados acionáveis corrigidos; nenhuma issue em aberto.

Issues para o GitHub

Só os achados ainda abertos viram issue; os corrigidos já estão nesta versão. Nenhum achado é explorável a ponto de pedir advisory privado.

Nenhuma issue em aberto: todos os achados acionáveis foram corrigidos nesta versão.